Centre for Digital Public Goods

NATIONAL STUDENT CASE COMPETITION '26

DigiYatra's Expansion into Private-Sector Identity Services

#2 Policy & Regulation Track

TEAM CHAKRAVYUH

ST. XAVIER'S COLLEGE, KOLKATA



DRISHTI SONTHALIA



MANDEEP SHARMA



PRAMITA CHOUDHURY



SHAURYA VIJAY SINHA



SUBHAM AGARWAL

THE EXPANSION PROBLEM

DigiYatra must extend trust beyond airports without extending surveillance.

The Problem

38 airports live
expanding to 65 by 2027

100+ million
passenger journeys completed to date (Jun 2026)

H2 2026–2027
Foundation's own confirmed timeline to pilot non-aviation use cases

Not Confirmed
DYF has only signalled interest

RISK-TIER STRIP

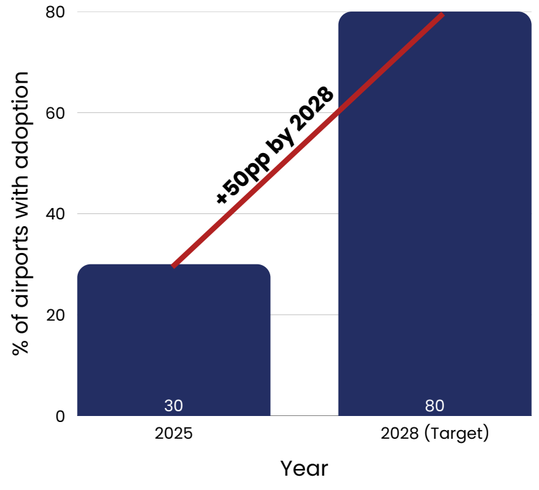
High — Prohibit

Conditional

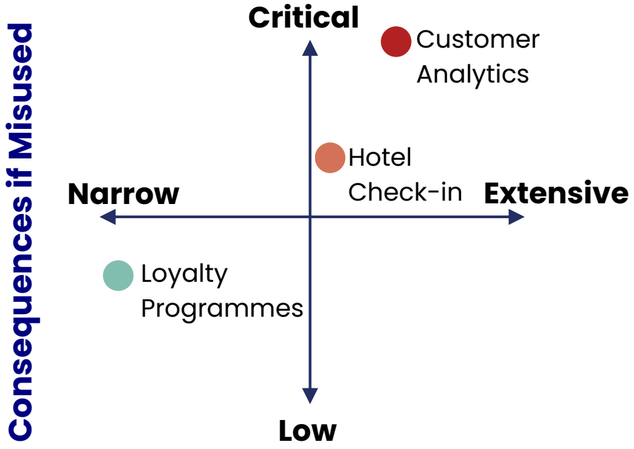
Low — Permit

Every new use case gets classified before approval.

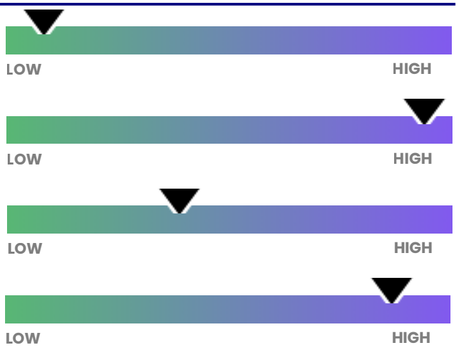
Risk Landscape



Digi Yatra Foundation, Dec 2025



Policy Levers



Slider = recommended stringency, Low to High

Why Proportionality?

Under the **Puttaswamy Framework**, **expanding a credential's purpose without fresh justification** is precisely what proportionality review exists to catch

DigiYatra excels at **narrow-purpose**, **1:1 verification** but **lacks a framework for purpose-bound reuse outside airports**—the gap this deck fills.

Two structural risks compound this: **bundled consent** obscures what users agree to, while **exclusion risks** denying service after a failed scan or a missing smartphone. Both require **auditable safeguards**.

Our recommendation: a **risk-tiered certification framework** requiring purpose-bound tokenisation and phased, **DPIA-gated rollout** — not a blanket access grant.

NECESSITY FAILS AS PROPOSED, NOT IN PRINCIPLE

DigiYatra's purpose is drifting toward commercial use—Puttaswamy's test shows where the current design fails, not where biometric expansion must

Puttaswamy Framework

Is there a legal basis? → **LEGALITY**

No statute authorises biometric use beyond airport access—DigiYatra's legal basis does not extend to hotels

Is the objective legitimate? → **LEGITIMATE AIM**

Faster check-in is a business interest, not a public interest—Puttaswamy needs the aim itself justified, not just the outcome

Is facial ID necessary? → **NECESSITY**

Necessity ≠ Convenience—even DigiYatra's own architecture favours returning a verification result only, not raw biometric data, wherever possible.

Do benefits outweigh risks? → **PROPORTIONALITY**

Purpose-bound, short-lived tokens (per the proposed Trust Framework) reduce downstream risk—but don't independently satisfy Necessity

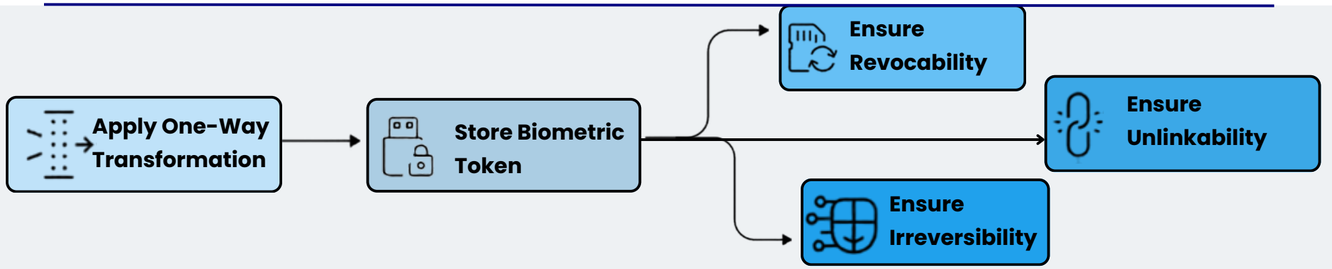
OVERALL: FAILS NECESSITY AS PROPOSED — a 1:1 verification-only model (per DigiYatra's own architecture) would satisfy necessity; a reusable biometric credential does not

Why the Puttaswamy Framework?

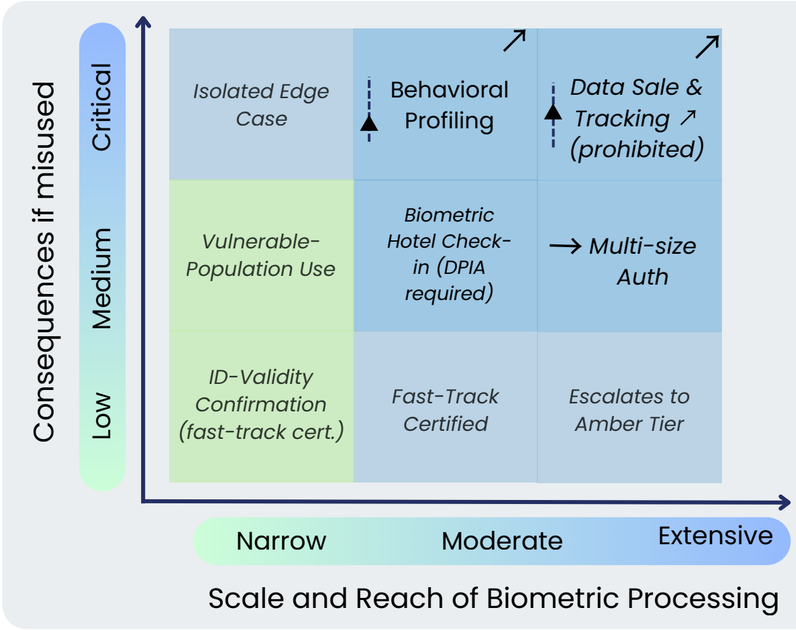
PRIVACY AS A RIGHT: Puttaswamy limits unjustified biometric intrusion, even when users consent.

NECESSITY OVER CONVENIENCE: Test less intrusive alternatives first—convenience is not enough.

ISO Framework



Risk Analysis: Private Sector



Hotel check-in sits at Medium–Extensive scale, Medium–High consequence—squarely in the zone requiring DPIA and purpose-specific certification (not blanket 'DigiYatra access') before any pilot

- Green — Low risk, fast-track eligible
- Blue — Medium risk, DPIA required
- Teal — Critical, escalates to Amber/Red tier

Legal and risk analysis converge: expansion requires a phased, certified pathway with sandboxing and sunset review—not direct rollout.

THE GAP IS NOT DIGIYATRA'S TECHNOLOGY—IT IS ITS LEGAL FOUNDATION

DYBBS was never passed by Parliament; DPDP rules apply, but DigiYatra Foundation lacks enforcement authority.

IIMB
तेजस्वि नावधीतमस्तु

Solving Trust

Layer 3
Digiyatra Foundation
Section 8 non-profit, outside RTI Act

Layer 2
DPDP Act 2023 + Rules 2025
Parliamentary law, binding independently

Layer 1
DYBBS Policy
MoCa Circular, never passed by Parliament

Fix: Statutory mandate for DYF
Modeled on UIDAI (Aadhar Act), NPCI (RBI)
Adds certification power + RTI coverage

29% enrolled without knowing (2024 passenger survey)

Weak
Section 6 + Rule 3
Binding regardless of DYBBS

Strong
RTI exclusion blocks
Independent audit access
No enforcement power

The rules are already strict—DPDP applies independently of DYBBS. What's missing is DYF's legal authority to enforce them. A statutory mandate, modelled on UIDAI and NPCI, closes that gap

Function Creep

Authentication System
Matches face to credential

Consent Gate
Seperate, logged opt- in required

Loyalty system
Personalisation, analytics

Output: yes/no token only
Raw face data never leaves here

No access by default

DPDP Section 6 + Rule 3: no data crosses without a fresh, distinct consent event

SCOPE & DESIGN GAPS

Where DigiYatra's rules don't yet distinguish risk levels

1. **Ban passive/1:N scanning**
   - **Test Failed:** Legality—DYBBS is policy, not statute
   - **Current gap:** No DPDP clause separates 1:1 from 1:N
   - **Fix required:** New classification rule under DPDP §6
2. **Mandatory pre-deployment DPIA**
   - **Legal Basis:** DPDP Rules 2025, Rule 12
   - **Current gap:** DPIA tied to SDF status, not risk
   - **Fix required:** Auto-trigger by processing type

Why this matters: these two gaps are the entry point for surveillance creep—close them and every downstream use case gets safer by design.

ACCESS & ENFORCEMENT GAPS

Who can reach the data, and what happens when rules break

1. **Restrict govt access to private facial data**
   - **Legal Basis:** DPDP §17 — State exemption clause
   - **Current gap:** Open-ended access, incl. NATGRID
   - **Fix required:** Closed agency list + judicial sign-off
2. **Independent audit + automatic penalties**
   - **Legal Basis:** 12 audit + DPDP §33 (₹250 Cr penalty)
   - **Current gap:** Penalty is financial-only, live access
   - **Fix required:** Auto Red-tier revocation on violation

Why this matters: enforcement without automatic revocation lets a violating operator keep using DigiYatra through the entire Board process.

Informed Consent

DPDP Requirement	Standalone Notice	No Bundling	Equal Non-Biometric Lane	Easy Withdrawal
Legal Basis	Rule 3	Rule 3	Puttaswamy test	Section 6(4)
Digiyatra Today	Partial	Fails	Unverified	Unclear
Required for Private-Sector Certification	Mandatory	Mandatory	Audited (±20%)	One- tap

Real enrollment data shows 29% of users were signed up without realising it—this scorecard defines what genuine consent requires to close that gap.

Certify First, Legislate Later—A Phased Path That Doesn't Wait on Parliament

A phased path DYF can execute unilaterally — legislative change comes later, without blocking early rollout

Phased Timeline

		Q3-Q4 2026	2027	2028+
Governance	Framework Design		Statutory mandate for DYF	Annual re-certification
Technical		DPIA+tokenisation build	Independent audit	Continuous monitoring
Pilot/Rollout		Sandbox: 1-2 hotels	Certified Green-tier rollout	Cyan-tier expansion

Feasibility Sequencing

PHASE 1 — CERTIFY BEFORE LAUNCH

1	2	3	3	4	4	6
Risk-Tier Certification Framework	Verify, Don't Collect + Tokenisation	Purpose Firewall	1:1 vs 1:N Statutory Distinction	Commercial Misuse+ DPIA/Audit		Statutory Mandate

Pins ranked 1–6 by implementation speed—how fast DYF could certify each fix if it started today, not by importance

Bright-Line, Applied

CATEGORY A — UNRESTRICTED

- 1:1 airport verification only
- No new consent event needed

CATEGORY B — CONSENT-GATED

- Loyalty recognition, behavioural analytics
- Standalone Rule 3 notice + likely SDF audit

CATEGORY C — PROHIBITED

- 1:N scanning, cross-sector data sharing
- No certification path exists

Verdict

DigiYatra should expand into the **private sector now** — through certification, not legislation. DPDP, Puttaswamy, and **ISO 24745/30136** already give DYF enough legal grounding to launch a **Green/Teal/Blue** framework immediately: purpose-bound tokenisation, mandatory pre-launch **DPIA**, no raw biometric leaving the device. Statutory backing for DYF follows in parallel to close the enforcement gap — not as a blocker. **Certify now. Legislate alongside it.**

Annexure

- Supreme Court Observer: Constitutionality of Aadhaar, Judgment Summary
- Bar and Bench: Proportionality Test for Aadhaar, the Supreme Court's two approaches
- Oxford Human Rights Hub: Defining the Right to Privacy in India in light of Justice KS Puttaswamy
- Ada Lovelace Institute, "An eye on the future" (risk-tiered biometrics governance recommendations)
- Hupont et al., "Face Recognition: to Deploy or not to Deploy? A Framework for Assessing the Proportional Use of Face Recognition Systems in Real-World Scenarios"
- Office of the Australian Information Commissioner, "Facial recognition technology: a guide to assessing the privacy risks"
- Office of the Victorian Information Commissioner, "Biometrics and Privacy: Issues and Challenges"
- Internet Policy Review, "Navigating data governance risks: Facial recognition in law enforcement under EU legislation"
- arXiv, "How to Do It Right: A Framework for Biometrics Supported Border Control" (EURODAC function creep case)
- European Data Protection Board - Opinion on Facial Recognition at Airports (2024)
- The India Forum - "Digi Yatra: Service or Surveillance?" (2024)
- DPDPA.com, "Vendor Data Processing Agreements Under DPDPA: Complete Guide"
- Glocert International, "DPDPA Vendor and Processor Due Diligence"
- Concur, "Dealing With Third Party & Vendor Consent Risk Under DPDP Act"
- MIT Technology Review, "Data leak exposes unchangeable biometric data of over 1 million people" (BioStar 2)
- arXiv, "On the Risk of Cancelable Biometrics" (ISO 24745/30136 properties: irreversibility, revocability, unlinkability)
- arXiv, "Cybersecurity: Past, Present and Future" (OPM fingerprint breach)